

The State of AI Tool Sprawl, Q1 2026

A 1,000-Repository Baseline on AI Governance Evidence and Approval Visibility

- Report ID: ai-tool-sprawl-q1-2026
- Version: v1
- Run ID: sprawl-ai1000-clean-pci-20260305T130344Z
- Campaign design: baseline-only, public-repository cohort, clone-sourced scan artifacts
- Wrkr commit pin: 77f547a75494b735da5cba500e3c82f3731e24cf
- Published by Centre for AI Security and Integrity (CAISI). Contact: david@caisi.dev. Full artifacts: github.com/Clyra-AI/safety.

Authorship and Affiliation

David Ahmann - Head of Cloud, Data and AI Platforms at CDW Canada ([LinkedIn](#))

Talgat Ryshmanov - Principal DevSecOps Consultant at Adaptavist ([LinkedIn](#))

About CAISI

The Centre for AI Security and Integrity (CAISI) publishes independent, reproducible research on AI agent governance. Every finding is backed by machine-generated artifacts, deterministic queries, and open methodology. CAISI exists because the gap between AI agent deployment and AI agent governance is growing faster than any single vendor, regulator, or standards body can close, and the organizations facing the consequences need empirical data, not opinion.

All research is published at caisi.dev with full artifacts at github.com/Clyra-AI/safety. The tools used in CAISI research are open source.

Executive Summary

This report measured AI governance posture across **1,000 public repositories** using a deterministic baseline scan. The strongest signal is not destructive AI tooling prevalence. It is governance opacity. In the measured cohort, **39.4%** of repositories lacked verifiable AI governance evidence, **590 of 1,000** showed at least one SOC 2 proxy gap, **367 of 1,000** showed at least one PCI DSS 4.0.1 proxy gap, and **37.5%** showed an EU AI Act Article 50 transparency-proxy gap.

Approval visibility was also weak. The headline-scope inventory contained **800 detected non-source AI tools**. Of those, **750** had approval status that could not be deterministically established from the observed artifacts, while only **50** met the baseline-approved standard. That yields a **15:1** not-baseline-approved to baseline-approved ratio. In this report, that ratio means "unknown or unproven governance status relative to the baseline policy," not "15 dangerous tools for every safe one."

The same dataset also matters for what it did **not** show. This public-repository cohort produced **0%** destructive-tooling prevalence and **0%** approval-gate-absence prevalence in the deterministic headline scope. Those absences are expected in public code. They do not prove internal environments are safe. They show that the measurable public signal is audit unreadiness and evidence gaps, not active harmful runtime behavior. That distinction is the core finding of this report.

Key Findings (At a Glance)

- Organizations without verifiable governance evidence: 39.4% (394/1000)
- Organizations with at least one SOC 2 proxy gap: 59.0% (590/1000)
- Organizations with at least one PCI DSS 4.0.1 proxy gap: 36.7% (367/1000)
- Organizations with at least one EU AI Act Article 50 proxy gap: 37.5% (375/1000)
- Not-baseline-approved to baseline-approved ratio: 15:1

- Detected tools with approval-unknown status: 750/800
- Repositories with no detected non-source tools at current detector sensitivity: 618/1000
- Destructive-tooling prevalence in headline scope: 0%

Headline Integrity Block

All headline claims in this report map to one immutable run.

- Run ID: sprawl-ai1000-clean-pci-20260305T130344Z
- Artifact base path: runs/tool-sprawlsprawl-ai1000-clean-pci-20260305T130344Z/

Headline Numbers

Key	Headline number	Denominator
H1	39.4	all scanned repositories
H2	37.5	all scanned repositories
H3	15	baseline-approved tools
H4	0.75	all scanned repositories
H5	1000	fixed cohort
H6	0	all scanned repositories
H7	0	all scanned repositories

Artifact + Deterministic Query Map

Keys H1 through H7 map to canonical claim IDs, artifact paths, and deterministic queries in `claims/ai-tool-sprawlsprawl-q1-2026/claims.json`.

1) What We Scanned

The canonical cohort for this manuscript contains **1,000 public owner/repo targets** selected before execution and scanned in deterministic baseline mode. The runner cloned each repository, executed Wrkr against the local clone, derived per-target state, and then rebuilt the campaign aggregate and claims from the stored scan artifacts. The canonical run ID for the artifact set used here is `sprawlsprawl-ai1000-clean-pci-20260305T130344Z`.

Headline metrics in this report exclude `tool_type == source_repo`. That matters because raw detections are dominated by repository-native tooling signals. In the canonical run, the raw inventory contained **5,765** total tool rows. Of those, **4,965** were `source_repo` rows and **800** were non-source rows used for the headline scope.

Campaign Composition

Measure	Value
Repositories scanned	1000
Detected non-source tools	800
Raw detected tools	5765
<code>source_repo</code> rows excluded from headline scope	4965
Repositories with at least one detected non-source tool	382
Repositories with no detected non-source tool	618

This report uses "no detected non-source tools" intentionally. It is a detection statement, not a proof-of-absence statement.

2) The Evidence Gap

The strongest quantitative signal in this cohort is evidence and control opacity. The baseline scan found a large share of repositories where AI tooling or workflow artifacts were present, but verifiable governance evidence or control-aligned documentation was not.

Deterministic findings for this section come from `appendix/combined-appendix.json`, with the Article 50 headline also mirrored in `agg/campaign-summary.json`.

- Repositories without verifiable governance evidence: **39.4% (394/1000)**
- Repositories with at least one SOC 2 proxy gap: **590/1000**
- Repositories with at least one PCI DSS 4.0.1 proxy gap: **367/1000**
- Repositories with at least one EU AI Act Article 50 proxy gap: **37.5% (375/1000)**

Evidence tiers split cleanly across the cohort: **606** repositories landed in the `verifiable` tier and **394** landed in the `basic` tier. At the control level, the largest measured SOC 2 proxy gaps were CC7.1 (**394** repositories) and CC6.1 (**367** repositories), with a much smaller CC8.1 tail (**14** repositories). PCI DSS gaps concentrated entirely in 7.2 and 12.8 (**367** repositories each) in this run.

These are deterministic control proxies, not legal determinations. The report measures whether the observed artifacts did or did not satisfy the repository's configured proxy rules for those control families.

3) The Approval Visibility Gap

The approval story in this cohort is mostly an evidence story. The baseline pipeline did not find explicit "unapproved" markers in headline scope, but it also could not establish positive approval status for most detected tools.

Approval posture in headline scope	Count
Baseline-approved tools	50
Explicit-unapproved tools	0
Approval-unknown tools	750
Not-baseline-approved tools	750
Not-baseline-approved to approved ratio	15:1

Two numbers matter together:

- **750 of 800** detected non-source tools had approval status that could not be deterministically established.
- The cohort-wide average was **0.75** approval-unknown tools per scanned repository because **618** repositories had no detected non-source tools in headline scope.

That is why the ratio should not be read as a danger score. It is a governance visibility score. The measured problem is that organizations cannot prove approval posture from the artifacts their repositories expose.

4) What We Did Not Find

This public-repository cohort did not produce strong evidence for active dangerous-tooling prevalence.

- Destructive-capable AI tooling prevalence: **0%** in deterministic headline scope.
- Approval-gate-absence prevalence: **0%** in deterministic headline scope.
- Explicit-unapproved to approved ratio: **0**, meaning no explicit unapproval evidence was detected for headline-scope tools.

That absence is not a contradiction. It is the expected shape of a public-repository dataset. Public repositories rarely expose the live runtime connections, secrets, or production-side approval semantics where destructive behavior materializes. This is why the static sprawl scan and the OpenClaw runtime case study answer different questions.

The sprawl scan measures the "before" picture: inventory, approval visibility, and evidence posture. The OpenClaw report measures what can happen when agents do have live tool access under workload. Together, the two studies separate discovery problems from runtime-control problems.

5) Calibration and Data Quality

Before the 1,000-target campaign, the pipeline ran a fixed **50-target AI-native calibration cohort** (sprawl-ai50-clean-pci-20260305T125702Z). On that labeled cohort:

- non-source existence detection achieved **100% recall** and **100% precision**
- approval-unknown existence detection achieved **100% recall** and **100% precision**
- non-source count and unknown-count totals each matched expected totals at **100%**

The calibration set did **not** contain positive destructive-tooling or approval-gate-absence examples. As a result, the pipeline validated negative-class consistency for those dimensions, but this study still lacks a positive-example stress test for destructive public-repo findings.

The main data-quality qualifier for the canonical run is the zero-detection distribution:

- **618/1000** repositories had no detected non-source tools in headline scope
- **599/1000** still had `source_repo` detections even when headline-scope detections were zero
- **19/1000** had no detected tool rows of any kind

Those counts mean the dataset supports governance-opacity conclusions more strongly than broad prevalence claims about dangerous AI tooling in public repositories.

6) Implications

The measurable risk in this cohort is audit unreadiness. The data shows many repositories cannot demonstrate approval status, evidence posture, or control-aligned artifacts for detected AI tooling. For organizations operating under SOC 2, PCI DSS, or upcoming EU AI Act transparency obligations, that is already operationally significant.

The question this report raises is narrower and more defensible than "Do organizations have dangerous AI tools everywhere?" The question is: **can organizations prove they do not?** In this 1,000-repository cohort, the answer was frequently no.

For governance teams, that leads to three direct implications:

1. Discovery without evidence is incomplete.
2. Approval status has to be machine-readable if it is going to survive audit or incident review.
3. Public-repository scans are useful for visibility baselines, but runtime-control questions require separate measurement in live or simulated execution environments.

Limitations

- This study covers one public-repository cohort and does not measure private repositories, internal agent deployments, or production runtime environments.
- Headline metrics exclude `source_repo` rows by design. Raw totals are published separately because source-repo signals dominate the inventory.
- A zero in headline scope means "not detected by the deterministic pipeline in this cohort," not "does not exist anywhere in the organization."
- `baseline-approved` is a strict, policy-defined category. Tools outside that category are not automatically unsafe or non-compliant.
- Regulatory outputs in this report are deterministic control proxies, not legal conclusions.
- The calibration cohort contained no positive destructive-tooling or approval-gate-absence examples, so those dimensions remain under-tested for positive-case recall.

Threats to Validity

- Sample-selection bias: target selection favored active public AI-native repositories and may not represent broader enterprise code inventories.
- Visibility bias: public repositories reveal less about live approval workflows, runtime identities, and production credentials than internal environments do.
- Detector-coverage bias: language/framework conventions can affect whether non-source tooling is surfaced into headline scope.
- Mapping bias: control proxies depend on policy definitions and artifact interpretation rules, not on direct audit evidence from each organization.
- Temporal drift: repository contents and governance artifacts can change after the scan window closes.

Residual Risk

- Internal and private repositories may contain higher-risk tooling patterns than the public cohort surfaced.
- Organizations with basic evidence posture in public repositories may still lack verifiable approval paths or runtime controls internally.
- Static inventory alone cannot answer runtime questions about destructive execution, halt semantics, or approval enforcement under live workload.

Reproducibility Notes

- Canonical artifacts are under `runs/tool-sprawl/sprawl-ai1000-clean-pci-20260305T130344Z/`.
- Headline claims map to `claims/ai-tool-sprawl-q1-2026/claims.json`.
- Threshold policy is versioned in `pipelines/config/publish-thresholds.json`.
- The artifact manifest is stored in the canonical run under `artifacts/manifest.sha256`.
- Deterministic rebuild command:

```
pipelines/sprawl/rebuild_from_scans.sh \  
  --run-id sprawl-ai1000-clean-pci-20260305T130344Z \  
  --targets-file internal/repos-1000-clean.md
```

- PDF build command:

```
pipelines/common/build_report_pdf.sh --report-dir reports/ai-tool-sprawl-q1-2026
```

The measured gap in this cohort is governance opacity, not active destructive tooling prevalence. That is the result this v1 report documents.